Enclave - Roadmap Privacy e Security

Versione: 1.0 — Ottobre 2026 **Progetto:** Enclave — CLI AI privacy-first (Rust) **Autore:** Mauro

Premessa

Enclave è uno strumento AI *local-first*: le conversazioni vivono cifrate sul tuo disco (SQLCipher), la telemetria è assente e sei sempre tu ad approvare ciò che viene eseguito. Già oggi il progetto include: cifratura a riposo con master password, privacy guard che intercetta i dati sensibili prima dell'invio, tool con approvazione obbligatoria, export cifrato e un client MCP.

Questa roadmap raccoglie le idee per alzare ancora l'asticella su privacy e sicurezza, divise per impegno. Per ogni voce spieghiamo in modo semplice: cosa fa, cosa apporta al progetto e lo sforzo stimato (S = pochi giorni, M = una o due settimane, L = un mese o più).

Come leggere il documento

- Quick win: alto valore, sforzo basso. Da fare subito.
- Upgrade robusti: irrobustiscono fondamenta e controllo dei flussi. Breve/medio termine.
- Rivoluzionari: differenziano Enclave dagli altri strumenti. Medio/lungo termine.

A. Quick win

A1. Argon2id per la master key (Sforzo S)

Cosa fa: sostituisce, o affianca, PBKDF2 con Argon2id per derivare la chiave dalla password.

Cosa apporta: Argon2id è *memory-hard*, cioè richiede molta memoria per ogni tentativo. Questo rende gli attacchi a forza bruta via GPU molto più costosi e alza la resistenza del punto più critico di tutto il sistema: la chiave che protegge i dati.

Nota: va reso configurabile per non rompere i vault già esistenti.

A2. Memoria protetta (Sforzo S)

Cosa fa: tiene la master key bloccata in RAM (mlock) e impedisce che finisca nel file di swap o nei core dump di un crash (MADV_DONTDUMP).

Cosa apporta: oggi la chiave è in chiaro in memoria. Se il sistema usa lo swap o un crash genera un core dump, potrebbe finire su disco. Con questa protezione i segreti restano solo in RAM e non lasciano tracce.

A3. Egress ledger cifrato (Sforzo M)

Cosa fa: registra in modo cifrato e a prova di manomissione (catena di hash) ogni invio verso un provider: quale modello, l'impronta del payload, la mappa di redazione e la data/ora.

Cosa apporta: diventa un registro doganale di tutto ciò che lascia la macchina. Non contiene nulla in chiaro, ma ti permette in ogni momento di verificare cosa è uscito e di dimostrarlo. Rende tangibile la promessa di privacy.

A4. Auto-lock, blur e clipboard (Sforzo S)

Cosa fa: blocca l'app dopo un periodo di inattività, sfoca la vista quando la finestra perde il focus e svuota gli appunti dopo N secondi (con un controllo che evita di cancellare dati copiati da te nel frattempo).

Cosa apporta: riduce i rischi da scrivania — qualcuno che passa, uno screenshot, il contenuto degli appunti che resta in giro. Sono accorgimenti piccoli ma con un effetto percepito molto forte.

A5. Panic e duress password (Sforzo S)

Cosa fa: una scorciatoia che chiude e blocca subito l'app, e una *duress password* che apre un vault civetta invece di quello reale.

Cosa apporta: negabilità plausibile. Sotto costrizione mostri una conversazione innocua. È una feature tipica dei prodotti di sicurezza seri.

B. Upgrade robusti

B1. Sandbox reale per i comandi approvati (Sforzo M/L)

Cosa fa: esegue i comandi approvati dentro una gabbia: filesystem ristretto alla cartella di lavoro, rete disattivata di default, limiti di CPU e memoria. Su macOS tramite sandbox-exec, oppure dentro un container.

Cosa apporta: è il buco più grande oggi. Un comando che approvi gira con i tuoi privilegi pieni. L'approvazione umana resta, ma il raggio d'azione di un comando malevolo o di un semplice errore si riduce moltissimo. È il singolo intervento con il miglior rapporto tra sicurezza e beneficio.

B2. Taint tracking e classificazione (Sforzo M)

Cosa fa: segna messaggi e allegati come sensibili e garantisce che non vengano mai inviati a un provider remoto nei turni successivi. Oggi la redazione vale per la singola esecuzione.

Cosa apporta: chiude un buco. Una volta che un dato è entrato nel contesto, continuerebbe a viaggiare a ogni turno. Con il taint la protezione persiste per tutta la sessione.

B3. Policy-as-code per l'uscita dati (Sforzo M)

Cosa fa: un piccolo linguaggio di regole locali, in stile Cedar o Rego, ad esempio "classi sensibili solo verso ollama", "mai file .env", "nessuna rete nella sessione X".

Cosa apporta: trasforma la privacy da buona intenzione a regola verificabile e ripetibile, scritta una volta e applicata sempre dall'engine.

B4. Modalità air-gap per sessione (Sforzo S/M)

Cosa fa: l'opzione offline fa sì che la sessione non usi mai la rete, solo modelli locali.

Cosa apporta: garanzia assoluta per i lavori più delicati. Anche in presenza di un bug non può uscire nulla, perché la rete è spenta per quella sessione.

B5. Hardening contro il prompt injection (Sforzo M)

Cosa fa: tratta output di tool, file e markdown come contenuto non fidato; nessun tool-call originato da contenuto remoto senza una nuova approvazione; canary token per accorgersi di tentativi di esfiltrazione.

Cosa apporta: neutralizza la classe di attacchi più subdola degli agenti AI — istruzioni nascoste dentro documenti o pagine che spingono il modello a fare cose pericolose.

B6. Routing per sensibilità (Sforzo M)

Cosa fa: una valutazione locale (regex più riconoscimento entità) instrada automaticamente i prompt sensibili verso il modello locale Ollama.

Cosa apporta: il dato delicato non esce per default. La scelta di quale modello usare diventa una conseguenza automatica della sensibilità, non un compito dell'utente.

B7. MCP hardening (Sforzo M)

Cosa fa: allowlist dei server, capacità dichiarate, nessun passaggio automatico di variabili d'ambiente segrete, processo server isolato.

Cosa apporta: MCP è potente ma apre una porta verso processi esterni. Va reso esplicito e controllato cosa può fare ciascun server.

B8. Proxy, Tor e pinning TLS (Sforzo M)

Cosa fa: supporto a proxy SOCKS5 e indirizzi .onion, e certificato o TLS pinning per i provider.

Cosa apporta: nasconde l'origine del traffico (Tor) e impedisce attacchi man-in-the-middle (pinning). Utile in contesti ostili, giornalismo o ricerca.

B9. Guard semantico con NER locale (Sforzo M)

Cosa fa: affianca alle espressioni regolari un piccolo modello locale di riconoscimento delle entità (nomi, indirizzi, organizzazioni).

Cosa apporta: riduce i falsi negativi. Cattura dati sensibili che le regex non vedono, senza inviare nulla all'esterno.

B10. Sblocco hardware-backed (Sforzo S/M)

Cosa fa: usa Secure Enclave, YubiKey o WebAuthn per sbloccare la master key.

Cosa apporta: la chiave non è più solo una password, serve un fattore hardware. Alza molto l'asticella contro il furto del computer.

B11. Build riproducibili, release firmate e SBOM (Sforzo M)

Cosa fa: build riproducibili, binari firmati stabilmente, distinta dei materiali (SBOM) e audit della catena di fornitura.

Cosa apporta: garantisce che il binario che esegui sia esattamente il sorgente pubblicato. Collega Enclave alle buone pratiche di settore e alla conformità (anche CRA).

C. Rivoluzionari

C1. Local RAG cifrato con ACL per file (Sforzo L)

Cosa fa: indicizza i tuoi file con embedding calcolati localmente; la ricerca avviene sul tuo disco; invii al modello solo i brani che approvi.

Cosa apporta: puoi chiedere del tuo codice o dei tuoi documenti senza spedirli. È il salto che unisce utilità (un vero assistente sul tuo sapere) e privacy (il recupero dei dati non esce mai). Pochi strumenti lo fanno davvero.

C2. Sync end-to-end encrypted tra dispositivi (Sforzo L)

Cosa fa: sincronizza le sessioni tra i tuoi dispositivi con CRDT sopra cifratura end-to-end.

Cosa apporta: roaming tra computer senza rinunciare alla privacy. Nessun server vede il contenuto. Oggi passando da una macchina all'altra si perde tutto.

C3. DLP con giudice locale (Sforzo M/L)

Cosa fa: un piccolo modello locale rivede ogni payload in uscita e blocca le fughe di dati. È il guard attuale trasformato in giudice intelligente, sempre in locale.

Cosa apporta: un secondo paio d'occhi automatico prima che qualcosa esca, che unisce la velocità delle regex con la comprensione di un modello.

C4. Proof-of-redaction e divulgazione selettiva (Sforzo L)

Cosa fa: impegno crittografico (hash) sul testo originale, invio della versione redatta e, in seguito, possibilità di rivelare in modo verificabile cosa era stato tolto.

Cosa apporta: privacy dimostrabile. Puoi provare a posteriori cosa era stato protetto, senza averlo esposto prima.

C5. Split inference e secret sharing (Sforzo L, sperimentale)

Cosa fa: divide il prompt tra più provider con tecniche di secret sharing, così nessun singolo provider lo vede completo.

Cosa apporta: riduce la fiducia richiesta a un singolo fornitore. Oggi è ricerca, ma indica una direzione interessante.

Roadmap a ondate

Ondata A - Fondamenta (subito). A1 Argon2id, A2 memoria protetta, A3 egress ledger, A4 auto-lock/blur/clipboard, A5 panic e duress. Poi B1 sandbox, B4 air-gap, B5 anti-injection.

Ondata B - Controllo dei flussi. B2 taint tracking, B3 policy-as-code, B6 routing, B7 MCP hardening, B9 NER, B10 sblocco hardware.

Ondata C - Differenziazione. C1 local RAG, C2 sync E2EE, C3 DLP locale, C4 proof-of-redaction, C5 split inference. In parallelo B8 proxy/Tor e B11 build riproducibili.

Shortlist consigliata (le quattro da fare prima)

1. B1 - Sandbox dei tool approvati: massimo guadagno di sicurezza reale.
2. A1 e A2 - Argon2id e memoria protetta: fondamenta crypto solide.
3. A3 e B2 - Egress ledger e taint tracking: controllo e visibilità totale su cosa esce.
4. C1 - Local RAG cifrato: il salto rivoluzionario più utile e coerente con il progetto.

Nota su compliance (CRA)

Pubblicare Enclave come software libero non commerciale su GitHub lo tiene tendenzialmente fuori dagli obblighi pieni del Cyber Resilience Act (Reg. UE 2024/2847). Se nascerà un supporto commerciale o una versione "prodotto", si applicano doveri progressivi: prima steward, poi manufacturer. Le voci della sezione B11 (release firmate, SBOM, build riproducibili) restano comunque la base minima consigliata.